

NIST CSF 2.0 Risk Assessment

Executive Report — Apex Financial Services

Executive Summary

This report summarizes a cybersecurity risk assessment conducted for Apex Financial Services, a simulated 500-employee financial services company, following the NIST Cybersecurity Framework (CSF) 2.0. The assessment identified 18 critical information assets, evaluated 13 realistic threat scenarios drawn from current industry threat intelligence, and produced a scored risk register of 15 risks. Nine risks were rated High and none reached Critical, indicating a moderate but manageable risk posture with clear priorities for improvement. A parallel maturity assessment against all six NIST CSF 2.0 functions found current maturity concentrated at the "informal / inconsistent" level (2.0-2.8 average), against a target maturity of 3.5-4.2 across functions - the largest gaps falling in Govern and Detect. This report presents the top risks, the resulting risk heat map, maturity gaps, and the recommended actions and owners already documented in the accompanying Risk Treatment Plan.

Key Findings

- 9 of 15 identified risks (60%) were rated High; the remaining 6 were rated Medium. No risks reached Critical.
- The highest-scored risk is phishing-driven credential theft against the identity platform (R-001, score 16), reflecting the concentration of business impact in identity and access.
- Three risks tie for second-highest severity (score 15): privileged account abuse, ransomware against the customer database, and ransomware against the core banking system - all pointing to insufficient segmentation and backup resilience.
- Govern and Detect are the least mature CSF functions (average current maturity 2.0), while Identify and Protect are comparatively stronger (2.7-2.8), consistent with an organization with foundational IT controls but immature governance and monitoring practices.
- All 9 High-rated risks already have an assigned owner, remediation action, and target date in the Risk Treatment Plan.

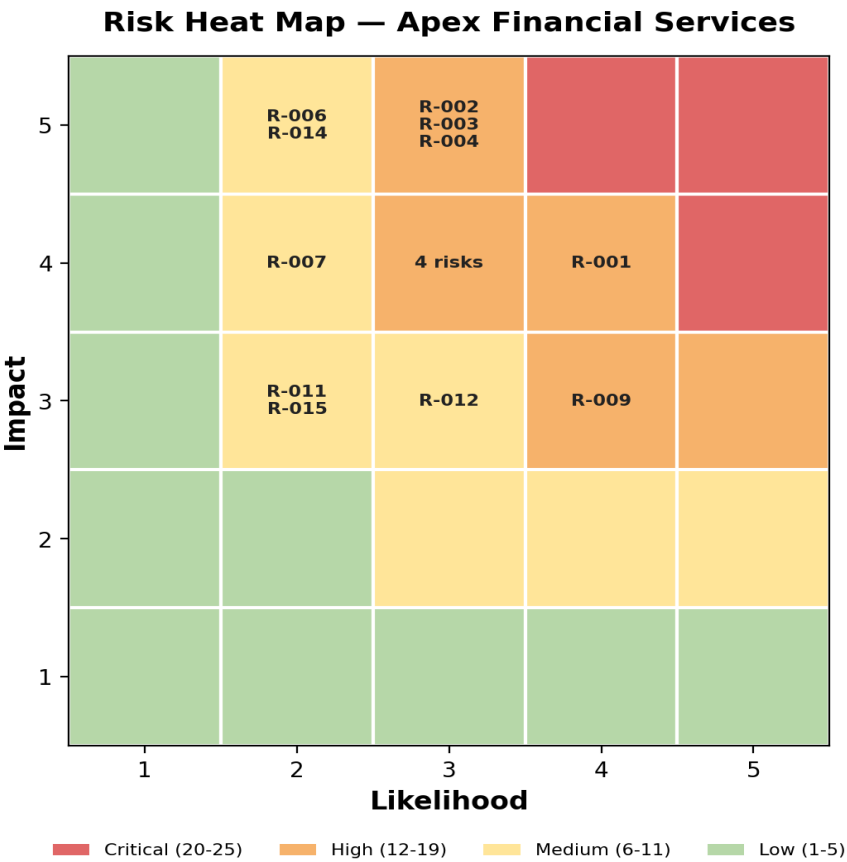
Top Risks

The six highest-scored risks from the Risk Register (Likelihood x Impact) are shown below, ranked by risk score.

ID	Risk Statement	Score	Level	Owner	Due
R-001	Phishing attack compromises employee credentials, enabling unauthorized access to Entra ID and Microsoft 365.	16	High	Security Engineering	11/06/2026
R-002	A compromised or misused privileged account in the PAM vault is used to escalate access across critical systems.	15	High	Security Engineering	11/21/2026
R-003	Ransomware encrypts the customer database, halting operations and risking data loss.	15	High	IT Infrastructure	11/21/2026
R-004	Ransomware disrupts the Core Banking / Loan Origination System, delaying loan processing and customer transactions.	15	High	IT Infrastructure	12/06/2026
R-005	A third-party vendor breach exposes Apex customer data shared through the Vendor Management Platform.	12	High	Vendor Risk Management	12/21/2026
R-008	A business email compromise scheme tricks staff into a fraudulent wire transfer via a spoofed executive request.	12	High	Finance / IT Security	10/22/2026

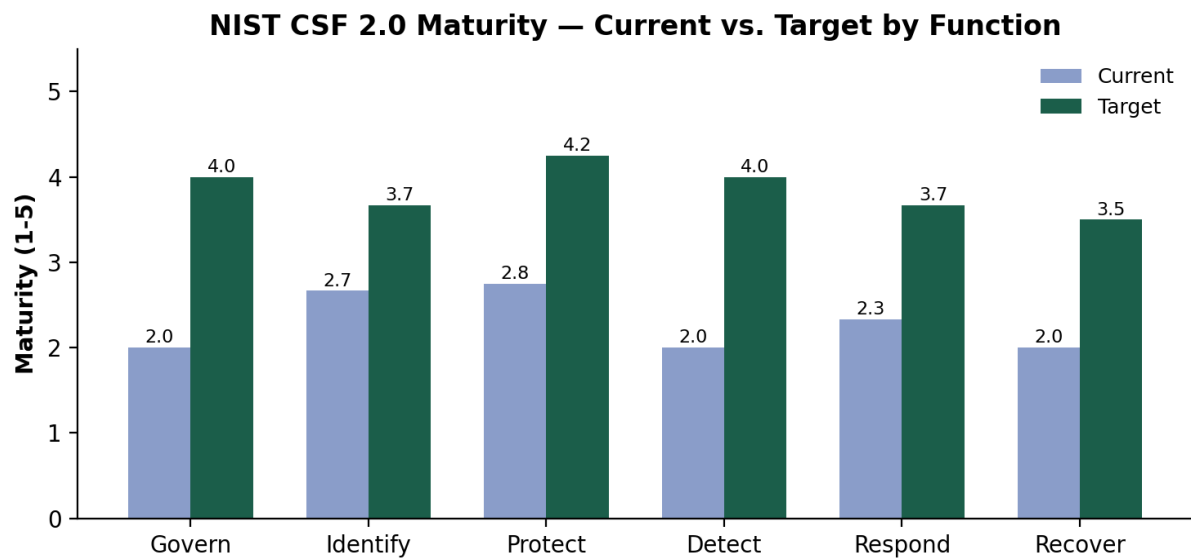
Risk Heat Map

Each cell shows the risk ID(s) scored at that Likelihood x Impact combination, color-coded by resulting risk level.



NIST CSF 2.0 Maturity Gaps

Current and target maturity were assessed across all six CSF 2.0 functions (1-5 scale). The chart below shows the average maturity per function; functions with the largest gap are prioritized for improvement.



Functions ranked by maturity gap (largest first):

Function	Current	Target	Gap
Govern	2.0	4.0	2.0
Detect	2.0	4.0	2.0
Protect	2.8	4.2	1.5
Recover	2.0	3.5	1.5
Respond	2.3	3.7	1.3
Identify	2.7	3.7	1.0

Recommended Actions

The following remediation actions, drawn from the Risk Treatment Plan, address the highest-scored risks identified in this assessment.

ID	Remediation Action	Owner	Due
R-001	Enforce phishing-resistant MFA (FIDO2/passkeys) for all Entra ID accounts and run quarterly phishing-simulation training.	Security Engineering	11/06/2026
R-002	Implement just-in-time privileged access and session recording for all PAM vault checkouts.	Security Engineering	11/21/2026
R-003	Deploy immutable, air-gapped backups for the customer database and test restoration quarterly.	IT Infrastructure	11/21/2026
R-004	Segment the Core Banking / Loan Origination System from general network access and enable endpoint detection on all hosts touching it.	IT Infrastructure	12/06/2026
R-005	Require SOC 2 reports and conduct annual security assessments for all vendors with data access.	Vendor Risk Management	12/21/2026
R-008	Implement dual-approval for wire transfers above a defined threshold and deploy email authentication (DMARC enforcement).	Finance / IT Security	10/22/2026

Management Priorities

- Close the identity and access gap first. R-001, R-002, and R-010 all trace back to identity and access control weaknesses (phishable MFA, standing privileged access, slow deprovisioning) - addressing these has the broadest risk-reduction impact.
- Validate backup and recovery resilience. Ransomware risk against both the customer database and the core banking system (R-003, R-004) depends on backup integrity that has not been fully tested end-to-end; a recovery test should be scheduled within the current quarter.
- Formalize governance before scaling further controls. Govern is the lowest-maturity function; without a documented risk strategy and clearly assigned accountability, technical controls implemented elsewhere will lack an oversight structure to sustain them.
- Treat AI tool usage as an active governance item now, not later. R-013 (AI tool data leakage) was included specifically because AI adoption is outpacing governance industry-wide; establishing an approved-tool policy now avoids costlier retrofitting later.

Apex Financial Services is a fictional company created for portfolio purposes. All assets, risks, scores, and findings in this report are simulated and do not represent any real organization.